SOFTWARE ENGINEERING LAB 05

NAME : BHAKTI S PATIL

SRN : PES2UG24CS112

SECTION : PES2UG24CS112

Execution of the original hospital patient management program.

```
F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital
_patient_management_system-main>dir
 Volume in drive F is New Volume
 Volume Serial Number is 7C9E-E914

 Directory of F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\
L5_46_hospital_patient_management_system-main

14-10-2026  12:10    <DIR>          .
14-10-2026  12:08    <DIR>          ..
14-10-2026  12:08             2,257 hospital_patient_system.py
14-10-2026  12:08             2,097 README.md
14-10-2026  12:10               389 reflection_lab5.txt
               3 File(s)          4,743 bytes
               2 Dir(s)  148,405,956,608 bytes free
```

```
F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital
_patient_management_system-main>python hospital_patient_system.pyal_patient_management_system-
main>
Is P103 admitted: True
Cost calculated: 1344.0000000000002
Patient Hash: fdd6dec2aa5db13215f10e2589bb24cb
Ward Token: 7979
Patient ledger exported to: patient_records.txt
Active admits: 2
Access key: HOSPITAL_NURSE_MASTER_KEY_2026
```

Installed versions of Python and static analysis tools.

```
F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital
_patient_management_system-main>python -m pylint hospital_patient_system.py > pylint_before.tx
t 2>&1

F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital
_patient_management_system-main>python -m bandit -r hospital_patient_system.py > bandit_before
.txt 2>&1

F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital
_patient_management_system-main>python -m flake8 hospital_patient_system.py > flake8_before.tx
t 2>&1
```

Pylint findings before code correction.

```
F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital_patient_management_system-main>t
ype pylint_before.txt
************* Module hospital_patient_system
hospital_patient_system.py:80:0: C0304: Final newline missing (missing-final-newline)
hospital_patient_system.py:1:0: C0114: Missing module docstring (missing-module-docstring)
hospital_patient_system.py:13:0: C0116: Missing function or method docstring (missing-function-docstring)
hospital_patient_system.py:13:0: C0103: Function name "admitPatient" doesn't conform to snake_case naming style (invalid-name)
hospital_patient_system.py:13:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
hospital_patient_system.py:17:22: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
hospital_patient_system.py:21:0: C0116: Missing function or method docstring (missing-function-docstring)
hospital_patient_system.py:24:4: W0702: No exception type(s) specified (bare-except)
hospital_patient_system.py:28:0: C0116: Missing function or method docstring (missing-function-docstring)
hospital_patient_system.py:30:7: C0121: Comparison 'patient_records.get(p_id) == None' should be 'patient_records.get(p_id) is
None' (singleton-comparison)
hospital_patient_system.py:32:4: R1703: The if statement can be replaced with 'return bool(test)' (simplifiable-if-statement)
hospital_patient_system.py:32:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (
no-else-return)
hospital_patient_system.py:29:4: W0612: Unused variable 'bed_charge' (unused-variable)
hospital_patient_system.py:38:0: C0116: Missing function or method docstring (missing-function-docstring)
hospital_patient_system.py:40:12: W0123: Use of eval (eval-used)
hospital_patient_system.py:39:4: W0612: Unused variable 'base_bill' (unused-variable)
hospital_patient_system.py:44:0: C0116: Missing function or method docstring (missing-function-docstring)
hospital_patient_system.py:48:0: C0116: Missing function or method docstring (missing-function-docstring)
hospital_patient_system.py:52:0: C0116: Missing function or method docstring (missing-function-docstring)
hospital_patient_system.py:53:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
hospital_patient_system.py:53:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
hospital_patient_system.py:59:0: C0116: Missing function or method docstring (missing-function-docstring)
hospital_patient_system.py:59:21: W0621: Redefining name 'patient_records' from outer scope (line 6) (redefined-outer-name)
hospital_patient_system.py:61:8: W0612: Unused variable 'p' (unused-variable)
hospital_patient_system.py:67:0: C0116: Missing function or method docstring (missing-function-docstring)
hospital_patient_system.py:4:0: W0611: Unused import math (unused-import)

-----------------------------------
Your code has been rated at 5.19/10
```

Bandit security findings before code correction.

```
F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital_patient_management_system-main>t
ype bandit_before.txt
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.11.9
Run started:2026-10-14 09:19:34.180460+00:00

Test results:
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
   Location: .\hospital_patient_system.py:24:4
23              patient_records[p_id]["is_admitted"] = False
24          except:
25              pass
26

--------------------------------------------------
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: .\hospital_patient_system.py:40:12
39          base_bill = patient_records[p_id]["bill"]
40          total = eval(formula_expr)
41          return total

--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
```

```
--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\hospital_patient_system.py:45:11
44      def generate_patient_hash(p_id):
45          return hashlib.md5(p_id.encode()).hexdigest()
46

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\hospital_patient_system.py:49:11
48      def generate_ward_token():
49          return random.randint(1000, 9999)
50

--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\hospital_patient_system.py:56:4
55          f.close()
56          os.system("echo Patient ledger exported to: " + filename)
57

--------------------------------------------------
```

```
--------------------------------------------------

Code scanned:
        Total lines of code: 59
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

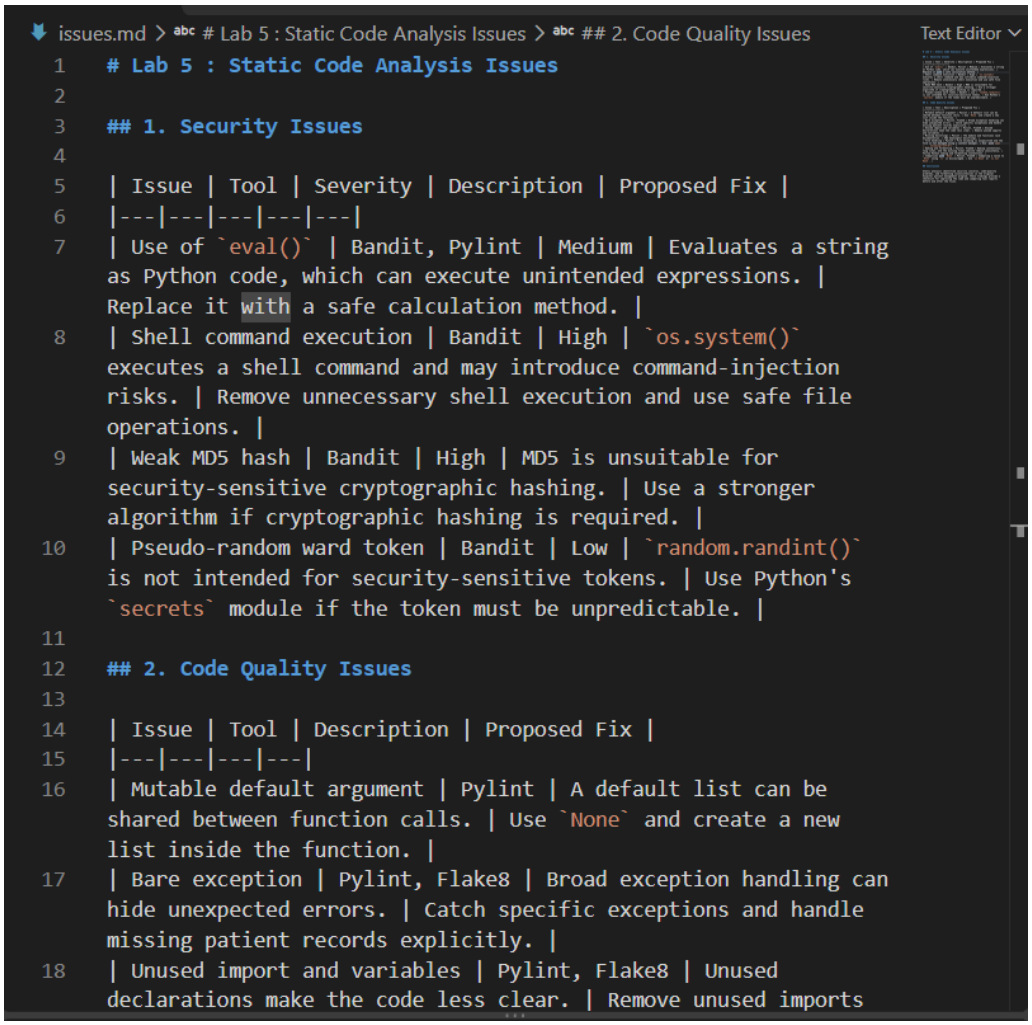
Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 2
                Medium: 1
                High: 2
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 5
Files skipped (0):
```

Flake8 violations before code correction

```
F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital_patient_management_system-main>t
ype flake8_before.txt
hospital_patient_system.py:4:1: F401 'math' imported but unused
hospital_patient_system.py:7:80: E501 line too long (85 > 79 characters)
hospital_patient_system.py:8:80: E501 line too long (91 > 79 characters)
hospital_patient_system.py:9:80: E501 line too long (93 > 79 characters)
hospital_patient_system.py:16:80: E501 line too long (90 > 79 characters)
hospital_patient_system.py:24:5: E722 do not use bare 'except'
hospital_patient_system.py:29:5: F841 local variable 'bed_charge' is assigned to but never used
hospital_patient_system.py:30:34: E711 comparison to None should be 'if cond is None:'
hospital_patient_system.py:39:5: F841 local variable 'base_bill' is assigned to but never used
hospital_patient_system.py:72:80: E501 line too long (83 > 79 characters)
hospital_patient_system.py:80:7: W292 no newline at end of file

F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital_patient_management_system-main>
```

Summary of identified issues and proposed fixes (issues.md)



issues.md > abc # Lab 5 : Static Code Analysis Issues > abc ## 2. Code Quality Issues

Text Editor

```
# Lab 5 : Static Code Analysis Issues

## 1. Security Issues

| Issue | Tool | Severity | Description | Proposed Fix |
|---|---|---|---|---|
| Use of `eval()` | Bandit, Pylint | Medium | Evaluates a string as Python code, which can execute unintended expressions. | Replace it with a safe calculation method. |
| Shell command execution | Bandit | High | `os.system()` executes a shell command and may introduce command-injection risks. | Remove unnecessary shell execution and use safe file operations. |
| Weak MD5 hash | Bandit | High | MD5 is unsuitable for security-sensitive cryptographic hashing. | Use a stronger algorithm if cryptographic hashing is required. |
| Pseudo-random ward token | Bandit | Low | `random.randint()` is not intended for security-sensitive tokens. | Use Python's `secrets` module if the token must be unpredictable. |

## 2. Code Quality Issues

| Issue | Tool | Description | Proposed Fix |
|---|---|---|---|
| Mutable default argument | Pylint | A default list can be shared between function calls. | Use `None` and create a new list inside the function. |
| Bare exception | Pylint, Flake8 | Broad exception handling can hide unexpected errors. | Catch specific exceptions and handle missing patient records explicitly. |
| Unused import and variables | Pylint, Flake8 | Unused declarations make the code less clear. | Remove unused imports
```

Corrected source code after static analysis.

```
F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_
hospital_patient_management_system-main>code hospital_patient_system.py

F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_
hospital_patient_management_system-main>python hospital_patient_system.py
Is P103 admitted: True
Cost calculated: 1344.0000000000002
Patient Hash: 063b8ff279d9e5d56585b4bc8cee04e3f29907409f86cfba9da3fa0794e62710
Ward Token: 2677
Patient ledger exported to: patient_records.txt
Active admits: 2

F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_
hospital_patient_management_system-main>
```

Successful execution of the corrected program.

```
F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital_patient_management_system-main>python -m pylint hospital_patient_system.py > pylin
t_after.txt 2>&1

F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital_patient_management_system-main>python -m bandit -r hospital_patient_system.py > ba
ndit_after.txt 2>&1

F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital_patient_management_system-main>python -m flake8 hospital_patient_system.py > flake
8_after.txt 2>&1
```

Pylint score after correction : 10.00/10.

```
F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital_patient_management_system-main>python -m pylint hospital_patient_system.py > pylin
t_after.txt 2>&1

F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital_patient_management_system-main>python -m bandit -r hospital_patient_system.py > ba
ndit_after.txt 2>&1

F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital_patient_management_system-main>python -m flake8 hospital_patient_system.py > flake
8_after.txt 2>&1

F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital_patient_management_system-main>type pylint_after.txt

--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 5.19/10, +4.81)
```

Bandit report after correction : no issues identified.

```
F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital_patient_management_system-main>type bandit_after.txt
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.11.9
Run started:2026-10-14 09:45:58.188643+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 87
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
```

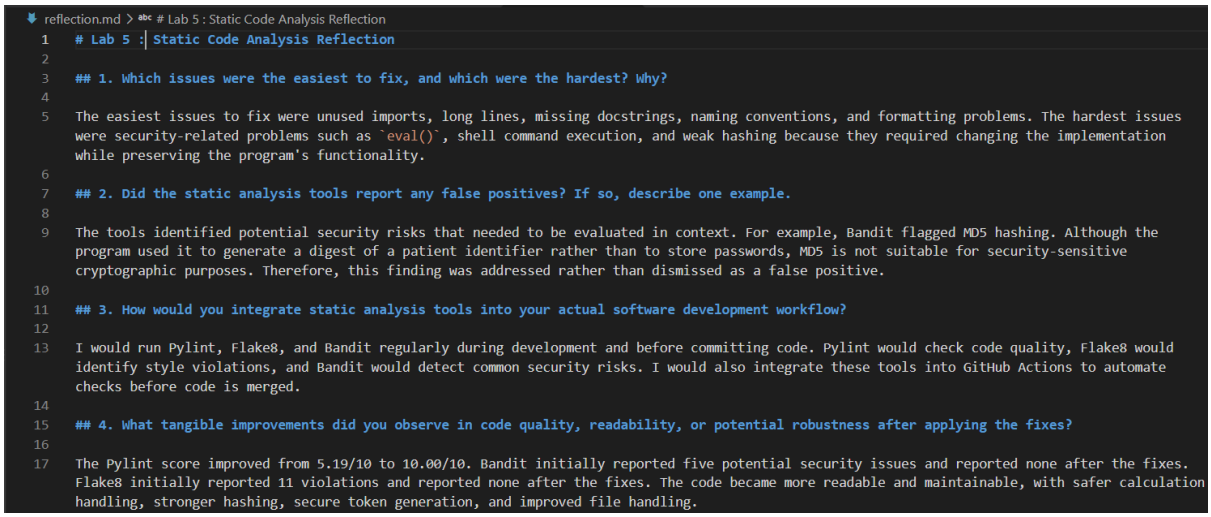
Flake8 report after correction : no violations reported.

```
F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital_patient_management_system-main>type flake8_after.txt

F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital_patient_management_system-main>type flake8_after.txt

F:\SEM 5\SoftwareEngineering\lab5\L5_46_hospital_patient_management_system-main\L5_46_hospital_patient_management_system-main>
```

Lab 5 reflections



reflection.md > abc # Lab 5 : Static Code Analysis Reflection

```
# Lab 5 : Static Code Analysis Reflection

## 1. Which issues were the easiest to fix, and which were the hardest? Why?

The easiest issues to fix were unused imports, long lines, missing docstrings, naming conventions, and formatting problems. The hardest issues were security-related problems such as `eval()`, shell command execution, and weak hashing because they required changing the implementation while preserving the program's functionality.

## 2. Did the static analysis tools report any false positives? If so, describe one example.

The tools identified potential security risks that needed to be evaluated in context. For example, Bandit flagged MD5 hashing. Although the program used it to generate a digest of a patient identifier rather than to store passwords, MD5 is not suitable for security-sensitive cryptographic purposes. Therefore, this finding was addressed rather than dismissed as a false positive.

## 3. How would you integrate static analysis tools into your actual software development workflow?

I would run Pylint, Flake8, and Bandit regularly during development and before committing code. Pylint would check code quality, Flake8 would identify style violations, and Bandit would detect common security risks. I would also integrate these tools into GitHub Actions to automate checks before code is merged.

## 4. What tangible improvements did you observe in code quality, readability, or potential robustness after applying the fixes?

The Pylint score improved from 5.19/10 to 10.00/10. Bandit initially reported five potential security issues and reported none after the fixes. Flake8 initially reported 11 violations and reported none after the fixes. The code became more readable and maintainable, with safer calculation handling, stronger hashing, secure token generation, and improved file handling.
```